SAFETY 4.0 · GÜNCEL KONULAR PROJESİ · HAFTA 5

SBOM / CVE / Patch

CEOTHERM Homojenizasyon Tesisi

Föy	Çıktı	Makine
Lab 5 · SBOM / CVE / Patch	Vulnerability Decision → EP 09 · 10 · 11	Fırın + soğutma kabini + biyet transfer arabası

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Zafiyet kaydı föydeki örnektir; makinemizin PLC firmware kütüphanelerinden birine denk geldiği varsayılmıştır. Ceotherm'in gerçek bileşen listesi (SBOM) elimizde yok; karar akışı bu varsayımla yürütülmüştür.

Verilen zafiyet kaydı

Alan	Değer
Bileşen	PLC firmware kütüphanesi (Component X)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev – Karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şart)

Şart	Bizim durumumuz	Sonuç
Bileşen var mı?	Fırın / soğutma / araba PLC'lerinin firmware'inde bu kütüphane kullanılıyorsa evet. SBOM ile doğrulanmalı	Kontrol et
Sürüm etkileniyor mu?	Sahadaki firmware sürümü 2.4 ise evet; farklıysa hayır	Kontrol et
Açık ulaşılabilir mi?	PLC'ler Hafta 2 hedefine göre DMZ arkasında ve ağdan izole. Yine de aynı OT ağından erişilebilir	Kısmen

Karar: Üç şart da sağlanırsa CVE bizi etkiler. Üçü aynı anda doğru değilse (ör. sürüm farklı) CVSS 9.8 olsa bile bizi doğrudan etkilemez. **Önce SBOM ve sürüm doğrulanmadan panik yapılmaz, yama da körlemesine uygulanmaz.**

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Hemen durdurmayız — koşullu. Üç nedenle:

- Bu makinede bir şarj 8–11 saat sürüyor. Ortada durdurmak 60 tona kadar biyeti hurdaya çıkarabilir. Durdurmanın da bir maliyeti ve riski var.
- Emniyet katmanı (Safety PLC / BMS) proses PLC'den ayrı. Açık proses PLC'sinde olsa bile insan koruması ayrı katmanda duruyor; yani açık doğrudan "ölüm riski" demek değil.

- Önce açığın gerçekten ulaşılabilir olup olmadığı doğrulanır. Ulaşılabilir ve emniyeti etkiliyorsa, devam eden şarj güvenli şekilde tamamlanır ve sonraki şarj başlatılmadan müdahale edilir.

İstisna: Açık aktif olarak istismar ediliyorsa veya doğrudan emniyet fonksiyonunu etkisizleştirebiliyorsa, güvenli duruma alıp durdurmak önceliklidir.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. PLC firmware'i canlı hatta doğrudan güncellenmez. Sebep: yama prosesi veya emniyet mantığını bozabilir ve bunu çalışan makinede fark etmek çok geç olur.

Adım	Nerede / nasıl
1. Test ortamı	Aynı model PLC'nin bulunduğu test tezgâhı veya üreticinin doğrulama ortamı
2. Fonksiyon testi	Yama sonrası sıcaklık profili, zamanlama, interlock'lar beklendiği gibi mi?
3. Emniyet testi	Yakma emniyeti, limit termostat, acil stop hâlâ çalışıyor mu?
4. Planlı pencere	İki şarj arasındaki duruşta, kayıt altında uygulanır
5. Geri dönüş planı	Yama sorun çıkarırsa eski sürüme dönülebilmeli (rollback)

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Etkileyebilir. PLC firmware'i hem prosesi hem emniyet mantığının bir kısmını taşıyorsa, yama emniyet fonksiyonunun doğrulanmış davranışını değiştirebilir. Nasıl anlarız:

- Yama notlarında (changelog) emniyetle ilgili modül, kütüphane veya zamanlama değişikliği var mı?
- Değişen fonksiyon, daha önce PL/SIL doğrulaması yapılmış bir emniyet fonksiyonuna mı dokunuyor?
- Dokunuyorsa: o emniyet fonksiyonunun doğrulaması (validation) yeniden yapılmalı. Yama, geçerli sertifikayı/onayı geçersiz kılabilir.

Kural: Emniyet fonksiyonuna dokunan hiçbir yama, yeniden doğrulanmadan "tamam" sayılmaz.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Yama hemen uygulanamıyorsa (üretici onayı yok, uzun duruş gerekiyor, eski cihaz desteklemiyor), açığı ulaşılamaz kılacak telafi edici önlemler alınır:

- Etkilenen PLC'yi ağda daha sıkı izole etmek (Hafta 2'deki conduit kurallarını sıkılaştırmak)
- Uzak erişimi o cihaz için tamamen kapatmak, yalnızca yerinde erişime izin vermek
- O bileşenin kullandığı portu/servisi kapatmak, böylece açık dışarıdan ulaşılamaz hale gelir
- Ek izleme: o cihaza yönelik anormal trafik için alarm kurmak
- Emniyet katmanının bağımsızlığını teyit etmek: proses PLC ele geçse bile insan korunur

Telafi edici önlem açığı yok etmez, ulaşılmasını engeller. Yama çıkar çıkmaz asıl çözüm uygulanır.

Eğitim çalışmasıdır, resmî denetim değildir. Zafiyet kaydı örnektir; gerçek SBOM ve sürüm bilgisi varsayıma dayanır.